

CyberSOC Platform

Admin Interface Specification Document

Version 1.0 | 2026-08-24

INTERNAL - TECHNICAL
SPECIFICATION

Document Purpose: This specification defines the complete administrative interface for the CyberSOC AI-Native Security Operations Center Operating System. It covers role-based access control (RBAC) implementation, dashboard components, CRUD operations for all managed entities, and integration requirements with the Billing and Licensing Architecture.

Target Audience: Platform Architects, Frontend Developers, DevOps Engineers, Security Officers, Product Managers

Go-Live Phase: Phase 1 - Critical Path Item

TABLE OF CONTENTS

1. Executive Summary.....	3
2. Administrative Role Matrix.....	4
2.1 Super Administrator.....	4
2.2 Organization Administrator.....	5
2.3 Billing Administrator.....	5
2.4 Read-Only Analyst.....	6
2.5 Permission Matrix Reference.....	6
3. Dashboard Architecture.....	8
3.1 System Overview Dashboard.....	8
3.2 User Management Dashboard.....	9
3.3 License & Revenue Dashboard.....	10
3.4 Usage Analytics Dashboard.....	11
4. User Management Module.....	12
4.1 User CRUD Operations.....	12
4.2 Bulk User Operations.....	13
4.3 User Session Management.....	14
5. Role & Permission Management.....	15
5.1 Role Definition Framework.....	15
5.2 Permission Assignment.....	16
5.3 Custom Role Creation.....	17
6. Tenant/Organization Management.....	18
6.1 MSSP Multi-Tenancy Model.....	18
6.2 Tenant Configuration.....	19
6.3 Resource Quotas.....	20
7. System Configuration.....	21
7.1 Global Settings.....	21
7.2 Integration Configuration.....	22
7.3 Security Policies.....	23
8. Audit Logging & Compliance.....	24
8.1 Audit Event Taxonomy.....	24
8.2 Log Retention & Export.....	25
8.3 Compliance Reporting.....	26
9. API Reference.....	27
9.1 Authentication Endpoints.....	27
9.2 User Management APIs.....	28
9.3 Tenant Management APIs.....	29
9.4 System Configuration APIs.....	30
10. Billing/Licensing Integration.....	31

10.1 License Inventory Sync.....	31
10.2 Usage Metering.....	32
10.3 Tier Enforcement.....	33
11. Security Requirements.....	34
11.1 Authentication Security.....	34
11.2 Authorization Controls.....	35
11.3 Data Protection.....	36
12. Implementation Roadmap.....	37
Appendix A: UI Mockup Descriptions.....	38
Appendix B: Database Schema Reference.....	39
Appendix C: Error Code Catalog.....	40

1. EXECUTIVE SUMMARY

The CyberSOC Admin Interface represents the central command and control surface for platform operators, enabling comprehensive management of users, organizations, licenses, security policies, and system configurations. This specification document defines the complete functional requirements, technical architecture, and integration patterns necessary to deliver a production-ready administrative capability as part of the platform's General Availability (GA) release.

1.1 Document Scope

This specification encompasses four primary administrative domains that collectively enable full operational control of the CyberSOC Platform. First, the Identity and Access Management domain provides complete lifecycle management for user accounts, authentication credentials, session state, and multi-factor authentication enrollment across all licensing tiers. Second, the Organization and Tenant Management domain implements the multi-tenancy architecture required for Managed Security Service Provider (MSSP) operations, including hierarchical resource isolation, per-tenant configuration, and cross-tenant visibility controls. Third, the License and Revenue Operations domain integrates with the six-tier pricing model to provide real-time license inventory tracking, usage metering, automated tier enforcement, and revenue analytics. Fourth, the System Configuration and Security domain offers centralized management of platform-wide settings, integration endpoints, security policies, and compliance frameworks.

1.2 Key Design Principles

Principle	Description	Implementation
Role-Based Access Control	All administrative actions governed by granular RBAC assignments with 47 distinct permissions across 8 self-managed and 40 managed roles	RBAC engine with 47 distinct permissions across 8 self-managed and 40 managed roles
Auditability	Every administrative action logged with full context for forensic analysis	Immutable audit trail with tamper-evident logging to S3
Multi-Tenancy Isolation	Complete data and configuration separation between tenants	Per-tenant organizations namespace-scoped Kubernetes resources
Self-Service Operations	Administrators can perform common tasks without manual intervention	Intuitive UI with workflow validation, bulk operations, and API endpoints
API-First Architecture	All administrative capabilities exposed via RESTful APIs	OpenAPI 3.0 specification with SDK generation for TypeScript and Python

1.3 Success Criteria

- All CRUD operations for Users, Roles, Tenants, and Configurations fully functional with proper validation
- Role-based permission enforcement achieving 100% coverage of administrative API endpoints
- Audit logging capturing 100% of state-changing administrative actions with sub-second latency
- Dashboard components rendering within 3 seconds for datasets up to 100,000 records
- Bulk operations supporting minimum 1,000 items per batch with progress indication
- Cross-browser compatibility achieved for Chrome 90+, Firefox 88+, Safari 14+, Edge 90+
- WCAG 2.1 AA accessibility compliance for all administrative interfaces

- Integration tests achieving >95% code coverage for admin API endpoints

2. ADMINISTRATIVE ROLE MATRIX

The CyberSOC Platform implements a hierarchical role-based access control (RBAC) system with four predefined administrative roles, each calibrated to specific operational responsibilities and trust levels. This section details the permissions, constraints, and typical use cases associated with each role. Organizations may also define custom roles by combining individual permissions, though the predefined roles cover the majority of deployment scenarios and are recommended as starting points for most implementations.

2.1 Super Administrator (super_admin)

The Super Administrator role represents the highest privilege level within the CyberSOC Platform, intended for platform owners, principal engineers, and designated emergency responders. Users assigned this role possess unrestricted access to all administrative functions, including the ability to modify system-level configurations, manage other administrators, and override tenant-level restrictions when necessary for troubleshooting or incident response. Due to the extensive privileges associated with this role, organizations should implement strict controls on its assignment, including mandatory approval workflows, regular access reviews, and just-in-time elevation mechanisms where possible.

Permission Domain	Capabilities
User Management	Create, read, update, delete any user account; reset passwords; unlock accounts; force password change
Role Management	Create, modify, delete custom roles; assign any role to any user; modify permission sets; manage role inheritance
Tenant Management	Create and terminate tenant organizations; modify tenant quotas; access tenant data (with audit trail)
System Configuration	Modify global platform settings; manage integrations; configure alerting rules; update license keys; manage API endpoints
Security Operations	View and export all audit logs; manage security policies; configure WAF rules; control IP allowlists; manage threat intelligence
Billing Operations	View revenue dashboards; generate invoices; apply credits; modify subscription tiers; process refunds

2.2 Organization Administrator (org_admin)

The Organization Administrator role is designed for day-to-day operational management within a single tenant organization. This role provides comprehensive control over the organization's users, configurations, and resources while maintaining strict isolation from other tenants and platform-level settings. In MSSP deployments, each customer organization typically has one or more Org Administrators who manage their analysts, configure detection rules, and monitor security posture without requiring intervention from the service provider's Super Administrators. This separation of duties enables scalable multi-tenant operations while maintaining clear accountability boundaries.

Permission Domain	Capabilities
User Management	Create, read, update, delete users within organization; reset passwords; unlock accounts; manage group memberships
Resource Management	Configure detection rules; manage playbooks; customize dashboards; configure alert routing; manage data retention

Permission Domain	Capabilities
Monitoring & Response	Access all security data within organization; acknowledge alerts; manage incidents; execute response
Configuration	Modify organization-level settings; configure branding; manage notification channels; set up SSO for

2.3 Billing Administrator (billing_admin)

The Billing Administrator role focuses specifically on financial operations, license management, and revenue-related functions. This role is essential for organizations operating under the Professional, Business, or Enterprise licensing tiers where usage tracking, invoice management, and cost optimization are ongoing concerns. Billing Administrators can view detailed usage metrics, generate financial reports, manage subscription plans, and handle customer inquiries about charges without requiring access to security data or user management functions. This role segregation supports compliance with financial controls and reduces the risk of unauthorized access to sensitive operational data.

Permission Domain	Capabilities
License Management	View license inventory; track seat utilization; request license allocation changes; view license expiration
Usage Analytics	View usage dashboards; generate usage reports; analyze consumption trends; set usage alerts; compa
Invoice Operations	View invoice history; download invoices; query charge details; dispute line items (creates support tic
Subscription Management	View current plan details; request plan changes (requires approval); view upgrade/downgrade option
Reporting	Generate cost allocation reports; create budget forecasts; export data for finance systems; schedule r

2.4 Read-Only Analyst (readonly_analyst)

The Read-Only Analyst role provides visibility into administrative data without modification capabilities, suitable for auditors, compliance officers, junior analysts, and stakeholders who require observational access without operational authority. Users with this role can view user lists, examine configurations, review audit logs, and access dashboards but cannot make changes, export sensitive data, or perform administrative actions. This role is particularly valuable during security audits, compliance assessments, and onboarding periods where new team members need to familiarize themselves with the platform's capabilities before receiving elevated privileges.

Permission Domain	Capabilities
Visibility	View user lists (masked PII); view role assignments; view tenant configurations; view system health s
Dashboards	Access all read-only dashboards; filter and sort data; export anonymized aggregates; save personal vi
Audit Logs	View audit log entries; search and filter logs; view event details; cannot export raw logs or access dele
Reports	View scheduled reports; access pre-built analytical views; cannot create custom reports or modify re

2.5 Comprehensive Permission Matrix

The following matrix provides a complete reference mapping between administrative roles and individual permissions. Each cell indicates whether the role possesses the permission (checkmark), lacks it explicitly (X), or inherits it conditionally based on context (circle). This matrix serves as the authoritative reference for permission assignments and should be consulted when configuring custom roles or evaluating access requests.

Permission	Super Admin	Org Admin	Billing Admin	Read-Only
users.create	✓	✓ (org only)	—	—
users.delete	✓	✓ (org only)	—	—
users.impersonate	✓	—	—	—
roles.manage	✓	—	—	—
tenants.create	✓	—	—	—
tenants.configure	✓	✓ (own only)	—	—
system.settings	✓	—	—	—
billing.view	✓	✓ (summary)	✓	✓ (limited)
billing.modify	✓	—	✓ (requests)	—
audit.export	✓	✓ (org only)	—	—
security.policies	✓	✓ (org only)	—	—
integrations.manage	✓	✓ (org only)	—	—

3. DASHBOARD ARCHITECTURE

The administrative dashboard system provides real-time visibility into platform operations, user activity, license utilization, and system health. Built on a modular component architecture, dashboards can be customized, saved, and shared among administrators with appropriate permissions. Each dashboard leverages the platform's unified analytics pipeline, ensuring consistent data freshness (maximum 30-second latency for real-time widgets) and supporting drill-down navigation from summary metrics to detailed record views.

3.1 System Overview Dashboard

The System Overview Dashboard serves as the administrative landing page, presenting a comprehensive snapshot of platform health, active sessions, recent alerts, and pending action items. This dashboard is visible to all administrative roles with varying levels of detail granularity. Super Administrators see platform-wide aggregates across all tenants, while Organization Administrators see data scoped to their specific organization. The dashboard employs a responsive grid layout that adapts from four columns on desktop displays to a single column on mobile devices, ensuring usability across all supported form factors.

Widget Name	Data Source	Refresh Rate	Description
Active Users Gauge	Redis session store	Real-time	Circular gauge showing currently authenticated users vs. license capacity
System Health Score	Aggregated health checks	60 seconds	Composite score (0-100) derived from API latency, error rates, and service availability
Alert Triage Queue	Elasticsearch alert index	30 seconds	Count of unacknowledged alerts by severity; click-through to full details
License Utilization Bar	PostgreSQL license table	5 minutes	Horizontal stacked bar showing allocated vs. used seats per tenant
Recent Audit Events	Elasticsearch audit index	30 seconds	Scrollable list of last 20 administrative actions with actor, time, and details
Infrastructure Status	Kubernetes API + Prometheus	60 seconds	Status indicators for each microservice pod showing CPU, memory, and health
Pending Approvals	PostgreSQL workflow table	15 minutes	Count of items awaiting approval (new users, role changes, license requests)
Geographic Distribution	GeoIP + Redis	5 minutes	World map heatmap showing login locations; highlights anomalies

3.2 User Management Dashboard

The User Management Dashboard provides centralized visibility and control over all user accounts within the administrator's scope of authority. For Super Administrators, this encompasses all platform users across every tenant organization. For Organization Administrators, the view is filtered to show only users belonging to their specific organization. The dashboard supports advanced filtering, search, and bulk operations, enabling efficient management of user populations ranging from handfuls to tens of thousands of accounts.

Widget Name	Data Source	Refresh Rate	Description
User Directory Table	PostgreSQL user directory	On-demand	Full-featured data table with sorting, filtering, column selection, and export

Widget Name	Data Source	Refresh Rate	Description
User Statistics Cards	Aggregated queries	5 minutes	Four cards showing Total Users, Active Today, New This Week
Role Distribution Pie	PostgreSQL role assignments	15 minutes	Interactive pie chart breaking down users by primary role; segmented by department
MFA Enrollment Status	PostgreSQL mfa_credentials	5 minutes	Horizontal bar showing enrolled vs. not enrolled; breakdown by role
Session Activity Timeline	Redis + Elasticsearch	30 seconds	Timeline visualization of login/logout events over past 24 hours
Pending Invitations	PostgreSQL invitations	2 minutes	List of outstanding invitations with sent date, expiry, resend options

3.3 License & Revenue Dashboard

The License and Revenue Dashboard provides Billing Administrators and Super Administrators with comprehensive visibility into the platform's commercial operations. This dashboard aggregates data from the Licensing Management System (LMS), payment processor webhooks, and usage metering pipelines to present real-time insights into license utilization, revenue recognition, churn risk, and growth opportunities. All financial figures can be displayed in multiple currencies with daily exchange rate updates from provider APIs.

Widget Name	Data Source	Refresh Rate	Description
Revenue Summary Cards	LMS + Stripe/PayPal	Hourly	Monthly Recurring Revenue (MRR), Annual Run Rate, Average Order Value
License Inventory Grid	LMS license pool	5 minutes	Visual grid showing license slots by tier and status (allocated, available)
Utilization Trend Line	Usage metering DB	Hourly	Line chart showing seat utilization over time with forecast projection
Tier Distribution	LMS subscriptions	Hourly	Donut chart showing subscriber distribution across Free/Professional/Enterprise
Churn Risk Indicator	ML scoring pipeline	Daily	Scorecard showing at-risk accounts with churn probability scores
Revenue Waterfall	Financial data warehouse	Daily	Waterfall chart showing MRR movements (new, expansion, contraction)

3.4 Usage Analytics Dashboard

The Usage Analytics Dashboard delivers deep insights into how platform features are consumed, enabling data-driven decisions about capacity planning, feature adoption, and user training priorities. This dashboard processes telemetry events from client applications, API gateway logs, and backend service metrics to construct comprehensive usage profiles. Administrators can slice data by time period, user segment, organization, feature category, or geographic region to identify patterns, anomalies, and optimization opportunities.

Widget Name	Data Source	Refresh Rate	Description
Feature Adoption Heatmap	Telemetry events	Hourly	Matrix showing adoption rate (users who used / total eligible) for key features
API Call Volume	API gateway logs	5 minutes	Time series chart of API calls broken down by endpoint category
Data Ingestion Rates	Pipeline metrics	Real-time	Gauges showing EPS (events per second) for SIEM, EDR, threat intelligence

Widget Name	Data Source	Refresh Rate	Description
Storage Consumption	Object storage metrics	Hourly	Stacked area chart showing storage usage by data type (logs, PO
Concurrent Sessions Graph	Session store	30 seconds	Area chart showing concurrent active sessions over time; break
Query Performance	Query engine metrics	5 minutes	Distribution histogram of query execution times; p50, p95, p99

4. USER MANAGEMENT MODULE

The User Management Module provides complete lifecycle administration for platform user accounts, spanning initial creation through eventual deactivation and data retention. This module implements the Create, Read, Update, Delete (CRUD) paradigm with comprehensive validation, audit logging, and notification workflows. All operations respect the principle of least privilege, ensuring administrators can only modify accounts within their authorized scope.

4.1 User CRUD Operations

Each user account operation follows a defined workflow with validation gates, side effects, and audit trail generation. The following specifications detail the data requirements, business logic, and API contracts for each operation. Implementations must ensure atomicity of state changes, meaning that either all side effects of an operation complete successfully, or none do, leaving the system in a consistent state even under failure conditions.

Operation	Required Fields	Validation Rules	Side Effects
CREATE	email (unique), display_name, phone_number, initial_password, password_complexity	Email format valid; initial password meets complexity; no duplicate email/phone	Creates user profile; assigns default role; triggers welcome email; logs creation
READ (Single)	user_id OR email	User exists; caller has visibility	Fetches user profile; returns masked phone number; updates hit count
READ (List)	filter params (role, status, pagination)	Filters applied; max 250/page	Applies filters; calculates pagination; returns list of user IDs
UPDATE	user_id + fields to modify	User exists; caller has edit权限; fields specified	Updates specified fields (e.g., email, phone, status); sends notification if email/phone changes
DELETE (Soft)	user_id	User exists; caller has delete权限	Sets deleted flag; updates last active timestamp; logs deactivation
DELETE (Hard)	user_id + justification	Soft-deleted > 90 days; retention policy met	Permanently removes user ID from system; triggers data purge if applicable

4.2 Bulk User Operations

Bulk operations enable efficient management of user populations at scale, supporting scenarios such as onboarding entire departments, applying policy changes across user segments, and offboarding departing personnel. All bulk operations execute asynchronously with progress tracking, partial failure handling, and rollback capabilities. Administrators initiate bulk operations via file upload (CSV template) or filtered selection from the user directory, then monitor progress through a dedicated job queue interface.

Operation	Input Method	Max Batch Size	Processing	Error Handling
Bulk Create	CSV upload (template)	1,000 users	Async job queue; parallel validation	Continues on individual failures; collects error log
Bulk Update	Filtered selection + CSV	500 users	Async job; row-by-row updates	Skips invalid rows; logs warnings; can be retried
Bulk Role Change	Selection + target role	250 users	Async job; validate role assignment	Rollback to previous role if assignment fails
Bulk Disable	Selection + reason	1,000 users	Async job; immediate session invalidation	Forces logout; releases resources
Bulk Export	Filter criteria + fields	10,000 users	Async generation; encrypted download	Secure download link (exp. 48h); admin approval

4.3 User Session Management

Session management capabilities allow administrators to monitor active user sessions, force logout for security reasons, and investigate suspicious access patterns. The session store maintains real-time visibility into authenticated connections across all access methods (web console, API tokens, SSO sessions, service accounts). Session data includes client information (IP address, user agent, geolocation), authentication method, session age, and last activity timestamp, enabling informed decisions about session termination.

Feature	Description	Permissions Required	Audit Impact
Active Sessions View	Real-time list of all active sessions for a user, showing device, IP, login duration, auth method	users:sessions:view	High, records session activity
Force Logout	Immediately invalidate specified session(s) or user sessions, terminating all active connections	users:sessions:terminate	High, sensitive event, includes reason
Global User Logout	Terminate ALL sessions for a user across all devices and methods, disabling login, triggers security alert, respects cooldown	users:sessions:terminate_all	High, sensitive event, triggers security alert, respects cooldown
Session Anomaly Detection	AI model flags sessions with unusual characteristics (impossible logins, rapid logins, unusual locations)	users:sessions:anomaly	Medium, flagged for review, typical hours
Session History Report	Historical listing of past sessions for users, including login/logout times, events logged, Exportable	users:sessions:history	Medium, detailed logs, Exportable per day

5. ROLE & PERMISSION MANAGEMENT

The Role and Permission Management subsystem implements the authorization layer that governs all access control decisions within the CyberSOC Platform. Built on a fine-grained permission model with 47 discrete permissions across eight functional domains, this subsystem supports both the predefined roles described in Section 2 and organization-defined custom roles. Permission checks are enforced at the API gateway layer, ensuring that authorization decisions are applied consistently regardless of which client application or integration initiates the request.

5.1 Role Definition Framework

Each role definition comprises a unique identifier, human-readable metadata, a set of granted permissions, and optional constraint parameters. Roles exist within a flat namespace globally (for system roles) or within an organization scope (for custom roles). The system prevents creation of roles that would grant equivalent or exceeding privileges to existing roles without explicit administrative intent, reducing the risk of privilege creep through redundant role definitions.

Field	Type	Constraints	Description
id	UUID (auto-generated)	Immutable after creation	Unique identifier for role reference in assignments and audits
name	String (3-100 chars)	Unique within scope; alphanumeric	Machine-readable identifier for programmatic references
display_name	String (3-200 chars)	Required; UTF-8 supported	Human-readable name shown in UI dropdowns and reports
description	Text (max 2000 chars)	Optional	Detailed explanation of role purpose and intended use cases
scope	Enum: [global, organization]	Default: organization; only one per organization	Determines visibility and assignment scope of the role
is_system_role	Boolean	Immutable; only set during initialization	Flag for predefined roles that cannot be deleted or have permissions
permissions	Array of permission strings	Must reference valid permissions; max 50	List of permissions granted to users assigned this role
created_at	Timestamp (ISO 8601)	Auto-set; immutable	Record creation timestamp for auditing and ordering
updated_at	Timestamp (ISO 8601)	Auto-updated on change	Last modification timestamp for change detection and caching

5.2 Permission Assignment Workflow

Modifying the permission set associated with a role triggers a structured approval workflow when the changes affect privileges that could impact security posture or compliance status. The workflow enforces separation of duties by requiring a second administrator (with equal or higher privileges) to approve sensitive permission grants. This two-person control prevents single-administrator privilege escalation attacks and creates clear accountability chains for audit purposes.

Step	Actor	Action	System Behavior
1. Request	Administrator	Submits permission change proposal	Validates proposal; if approved, updates permissions; if denied, logs reason

Step	Actor	Action	System Behavior
2. Review	Approver (different user)	Examines proposal; approves, rejects, or requests modifications	Triggers step 3; If reject: close with reason
3. Apply	System (automated)	Executes approved changes against role definition in database; invalidate permission cache	
4. Notify	System (automated)	Sends notifications to stakeholders	Email to requester and approver; in-app notification

5.3 Custom Role Creation

Organizations may define custom roles to address specific operational requirements not covered by the predefined roles. Custom roles are scoped to the creating organization and cannot be assigned to users in other tenants. The creation process guides administrators through permission selection using a domain-grouped interface that explains each permission's implications in plain language. Recommended permission combinations are offered as starting points for common use cases (e.g., "Security Analyst", "Compliance Viewer", "Help Desk Operator").

Use Case	Recommended Base Permissions	Rationale
Tier 1 SOC Analyst	alerts.view, alerts.acknowledge, incidents.view, incidents.read, investigations.view	Guides, reads, investigates, updates without modifying
Senior Incident Responder	All Tier 1 + incidents.update, incidents.resolve, cases.update, playbooks.execute, evidence.upload	Asks update, to playbooks, execute, evidence upload
SOC Shift Lead	All Senior + alerts.manage, incidents.assign, cases.assign, user.manage (org), reports.view	Escalates, user manage (org), reports, for shift management
Compliance Auditor	audit.view, audit.export, configs.view, policies.view, reports.view, sensors.view (PIN and add)	View, reports to view, to sensors (PIN and add) activity data for
MSSP Customer Admin	users.manage (org), configs.manage (org), integrations.manage (org), distributions.manage (org)	Tenants scope (org), distributions: MSSP customers manage

6. TENANT/ORGANIZATION MANAGEMENT

The Tenant Management subsystem implements the multi-tenancy architecture that enables the CyberSOC Platform to serve multiple independent organizations from a single deployment. This capability is fundamental to the Managed Security Service Provider (MSSP) operating model, where a single platform instance hosts dozens or hundreds of customer organizations, each with isolated data, dedicated configurations, and independent user populations. The tenant model also supports enterprise deployments where internal departments operate as separate tenants for administrative and compliance purposes.

6.1 MSSP Multi-Tenancy Model

In the MSSP operating model, the platform operator (the MSSP) maintains a privileged "provider" tenant that has cross-tenant visibility and management capabilities. Customer organizations exist as child tenants with strictly isolated data and limited visibility into the provider environment or sibling tenants. This hierarchy enables the MSSP to deliver branded, customized SOC services to each customer while maintaining operational efficiency through shared infrastructure and centralized management tools.

Characteristic	Provider Tenant (MSSP)	Customer Tenant	Technical Implementation
Data Visibility	Cross-tenant aggregate view of platform data	Only data owned by that customer	Data isolation via security with tenant_id predicate;
User Management	Can create/manage users in any tenant including their own	Can only manage users within own tenant	User records linked to tenant_id; foreign key constraints
Configuration	Platform defaults; can override	Child inherits provider defaults; can override	Hierarchical configuration system -> tenant -> user
Branding	Full white-label control; sets defaults for customers	Can define branded plates	Branding templates with locked vs. editable elements;
Support Access	Can access customer tenant for support	Can not access provider or other customers	Support mechanism requires ticket ID; full audit
Billing Visibility	Sees all customer billing; manages invoices and usage	Sees own billing	MSSP tenant-specific flag controls data access; aggrega

6.2 Tenant Configuration Options

Each tenant maintains a configuration record that controls platform behavior within that organization's scope. Configuration options span functional areas including security policies, data retention, integration settings, user experience customization, and operational parameters. The provider tenant can set platform-wide defaults that customer tenants inherit, while allowing customers to customize permitted options to match their specific requirements and preferences.

Category	Example Settings	Provider Control	Customer Override
Security Policies	Password complexity, session timeout	Set MFA requirements, IP whitelisting	Can lock down specific policies
Data Retention	Log retention (days), PCAP storage	Define max archive retention	Can limit (longer retention periods)
Alert Configuration	Severity thresholds, noise suppression	Provides default rule paths	Can modify rules, thresholds
Integrations	SIEM connection, EDR console, threat feeds	Pre-configured integrations	Can add custom integrations, credentials; sele

Category	Example Settings	Provider Control	Customer Override
Branding & UX	Logo, color scheme, login page text	Setup, templates and info, documentation links	Customization; locked elements within branding
Operational	Timezone, date format, number format	Control default dashboard layout, types, sorting flags	Enabled features; cannot access

6.3 Resource Quotas and Limits

Resource quotas prevent any single tenant from consuming disproportionate platform resources, ensuring fair distribution and predictable costs for the MSSP operator. Quotas are defined at the provider level and assigned to tenant plans (Free, Professional, Business, Enterprise). The system enforces quotas in real-time at the point of resource consumption, providing clear feedback when limits are approached or exceeded. Quota excess triggers alerting to both the affected tenant administrator and the provider operations team.

Resource	Free Tier	Professional	Business	Enterprise	Enforcement Point
User Seats	5	25	100	Unlimited	User creation API; UI shows X/Y used
Daily API Calls	1,000	50,000	500,000	Unlimited	API gateway rate limiter; 429 response
Storage (GB)	10	100	1,000	10,000+	Object storage bucket policies; upload reject
Concurrent Sessions	5	25	100	500	Session creation; oldest session terminated i
Custom Dashboards	3	25	100	Unlimited	Dashboard save endpoint; list/delete to free
Integrations	2 (built-in only)	25	25	Unlimited	Integration creation endpoint
Retention Days	30	90	365	730+	Config save validator; cannot exceed max
SSO/SAML	Not available	Available	Included	Advanced (IdP-initiated)	Initiated flag check at authentication

7. SYSTEM CONFIGURATION

The System Configuration module provides Super Administrators with centralized control over platform-wide settings that affect all tenants and users. These configurations govern core platform behaviors including authentication mechanisms, external integrations, security policies, and operational parameters. Changes to system configuration take effect according to defined propagation rules, with some settings applied immediately and others requiring service restarts or gradual rollout across the cluster.

7.1 Global Platform Settings

Global settings establish the baseline behavior of the CyberSOC Platform, providing defaults that tenant-specific configurations can optionally override within defined bounds. These settings are persisted in the platform configuration store with full version history, enabling rollback to previous states if a configuration change causes operational issues. The configuration UI presents settings in logical groups with inline documentation explaining the purpose and implications of each option.

Setting Group	Key Settings	Change Impact	Rollback Support
Authentication	Default session timeout (min), Password policy (length, complexity, rotation)	Immediate for session timeout; Password policy requires service restart	Full rollback to previous state
Email/Notifications	SMTP server settings, sender addresses, template defaults	Immediate for server settings; Template changes require UI refresh	Full rollback to previous state
Data Processing	Default retention periods, PII redaction rules	Applied to new data; Existing data requires manual reprocessing	Full rollback to previous state
API Gateway	Rate limit defaults, CORS policies, request size limits	Immediate for all settings	Full rollback to previous state
Feature Flags	Feature availability by tier, beta feature toggles	Immediate for all settings	Full rollback to previous state

7.2 Integration Configuration

The CyberSOC Platform integrates with numerous external systems to provide comprehensive security operations capabilities. The Integration Configuration panel centralizes the management of connection credentials, synchronization schedules, data mapping rules, and health monitoring for all integrated systems. Each integration type has a specific configuration schema validated against a JSON Schema definition, ensuring that required fields are present and values fall within acceptable ranges before the connection is activated.

Integration Type	Configuration Parameters	Authentication	Health Check
SIEM (Wazuh/Elastic)	Server URL, indices, query templates	API key or OAuth2, certificate mapping	Endpoint ping; log ingestion test
EDR (GRR/osquery)	Server URL, client labels, fetch ranges	API key or certificate, optional TLS	Client list fetch; execute sample query
Threat Intel (MISP/OpenCTI)	Base URL, taxonomies to sync, attributes	API key or OAuth2, optional TLS	Fetch recent threats; verify taxonomy sync
SOAR (TheHive/Cortex)	Server URL, case templates, analyzers	API key or OAuth2, optional TLS	Get case list; trigger sample analyzer
Ticketing (Jira/ServiceNow)	Base URL, project/queue mappings	Personal access token, optional TLS	Get ticket list; create test ticket

Integration Type	Configuration Parameters	Authentication	Health Check
Vulnerability (DefectDojo)	Base URL, product/type mappings, API key, token auth, SSO, \$600 points per scan	API key, token auth, SSO, \$600 points per scan	Verify product creation, scan success
Identity Provider (SAML2)	Metadata URL or manual entry, attribute mappings, signing certs, IDP entity ID, SP entity ID	Metadata URL or manual entry, attribute mappings, signing certs, IDP entity ID, SP entity ID	Verify attribute reception

7.3 Security Policy Configuration

Security policies define the protective measures that the platform enforces automatically to safeguard data, prevent unauthorized access, and detect malicious activity. Policy configuration balances security effectiveness with operational usability, avoiding overly restrictive settings that would hinder legitimate security operations while maintaining strong defenses against real-world attack vectors. The policy editor provides preset profiles (Standard, High Security, Compliance-Focused) that can serve as starting points for customization.

Policy Domain	Configurable Parameters	Standard Preset	High Security Preset
Account Lockout	Threshold (failed attempts), Duration (pts, sec), Cooldown (min)	5 attempts, 30 sec, 15 min	10 attempts, 60 min lock, 30 min cooldown
Password Policy	Min length, uppercase, lowercase, digits, special chars, History (days)	12 length, 3 special, 24 history	14 length, 4 special, 45 history
Session Security	Timeout idle (min), timeout absolute (hours), Max concurrent, Max concurrent per IP	30 min idle, 8 hours abs, 5 concurrent, 15 concurrent per IP	15 min idle, 4 hours abs, 3 concurrent, 10 concurrent per IP
IP Restrictions	Allowlist mode, allowed CIDRs, Geo-blocking by country, VPN detection	Geo-blocking by country, VPN detection	Allowlist; block high-risk countries; VPN detection
API Security	Rate limit (req/min), payload size (MB), TLS min version, Allowed cipher suites	100 req/min, 10 MB, TLS 1.2, TLS 1.2 restricted ciphers	60 req/min, 5 MB, TLS 1.3, TLS 1.3 restricted ciphers
Data Protection	PII fields list, encryption at rest algorithm, Backup frequency, Key rotation	Standard PII, AES-256, Daily, 90 days	Compliance PII, AES-256-GCM, AES-256-GCM

8. AUDIT LOGGING & COMPLIANCE

Comprehensive audit logging forms the foundation of the CyberSOC Platform's compliance and forensics capabilities. Every state-changing administrative action generates an immutable audit event capturing the actor identity, action performed, target entity, before/after state diff, timestamp, and source context (IP address, user agent, session ID). Audit events are written to a dedicated Elasticsearch cluster with append-only semantics, preventing retroactive modification or deletion by any user including Super Administrators.

8.1 Audit Event Taxonomy

Audit events are classified into a hierarchical taxonomy that supports efficient querying, compliance reporting, and alert rule configuration. The taxonomy comprises eight top-level categories aligned with functional domains, each containing specific action types that capture the semantic intent of the recorded operation. This structure enables compliance officers to quickly locate relevant events (e.g., "all user permission changes in Q3") and security analysts to detect suspicious patterns (e.g., "multiple failed login attempts followed by successful authentication and mass data export").

Category	Event Types	Key Attributes	Retention
AUTHENTICATION	LOGIN_SUCCESS, LOGIN_FAILURE, LOGOUT, PASSWORD_CHANGE, MFA_VERIFY, MFA_FAIL	Username, IP, Password, Device, MFA Agent, User Agent, HTTP Code	90 days (Active), 180 days (Archive)
USER_MANAGEMENT	USER_CREATE, USER_UPDATE, USER_DELETE, USER_LOCK, USER_UNLOCK, USER_RESET_PASSWORD	User ID, Username, Email, Phone, Last Modified, Created By	7 years (Immutable)
ROLE_MANAGEMENT	ROLE_CREATE, ROLE_UPDATE, ROLE_DELETE, PERMISSION_ASSIGN, PERMISSION_REVOKE, ROLE_MAP_UPDATE	Role ID, Permissions, Role Name, Assigned To	7 years (Immutable)
TENANT_MANAGEMENT	TENANT_CREATE, TENANT_UPDATE, TENANT_DELETE, TENANT_SUSPEND, TENANT_RESUME, TENANT_TRANSFER	Tenant ID, Name, Status, Owner, Region	7 years (Immutable)
CONFIGURATION	SYSTEM_CONFIG_CHANGE, INTEGRATION_CONFIG_UPDATE, ALERT_TEMPLATE_CREATE, ALERT_TEMPLATE_DELETE	Config Path, Value Before, Value After, Modified By	7 years (Immutable)
DATA_ACCESS	DATA_EXPORT, DATA_VIEW_PII, DATA_DOWNLOAD, DATA_UPLOAD, DATA_DELETE, DATA_RESTORE	Data Type, General Fields, PII Fields, Operation, User, IP	90 days (Active), 2 years (Archive)
SECURITY_EVENT	ALERT_ACKNOWLEDGE, INCIDENT_CREATE, INCIDENT_UPDATE, INCIDENT_CLOSE, INCIDENT_RESOLVE, INCIDENT_PLAYBOOK_EXECUTE	Alert ID, Incident ID, Case Owner, Status, Resolution, Playbook Name	7 years (Immutable)
BILLING_OPERATION	LICENSE_ALLOCATE, LICENSE_RELEASE, LICENSE_TRANSFER, LICENSE_RENEW, LICENSE_CANCEL	License ID, Product Name, Quantity, Unit Price, End Date	7 years (Immutable)

8.2 Log Retention and Export

Audit log retention periods align with regulatory requirements across multiple compliance frameworks including SOC 2 Type II, GDPR, HIPAA, and FedRAMP. The system implements tiered storage with hot storage (Elasticsearch, 90 days for active investigation), warm storage (compressed Elasticsearch snapshots, 2 years for compliance queries), and cold storage (object archive with immutable WORM protection, 7 years for legal hold). Automated policies manage tier transitions based on age, with options to extend retention for specific event categories or in response to legal hold requests.

Storage Tier	Technology	Age Range	Access Latency	Query Capability	Cost Tier
Hot	Elasticsearch cluster (SSD)	0 - 90 days	< 1 second	Full-text search, aggregations, filters	\$\$\$ (highest)

Storage Tier	Technology	Age Range	Access Latency	Query Capability	Cost Tier
Warm	Elasticsearch frozen indices (HDD)	90-180 days	5-30 seconds	Search, limited aggregations, no joins	\$100/TB/mo (moderate)
Cold	Object storage (WORM, compressed)	730-2555 days	Minutes to hours	Batch query via restore job; full-text search available	\$10/TB/mo (low cost)
Archive	Glacier Deep Archive (optional)	2555 hours	Hours	Full index restore required; significant lead time	\$1/TB/mo (minimal)

8.3 Compliance Reporting

The platform provides built-in compliance report templates that aggregate audit data into formats suitable for regulator submissions, auditor requests, and internal governance reviews. Reports can be generated on-demand or scheduled for automatic delivery (email, SFTP, cloud storage). Each report template maps to specific control requirements within major compliance frameworks, with coverage matrices maintained as framework versions update.

Report Template	Framework Mapping	Content Description	Typical Audience	Generation Frequency
User Access Review	SOC 2 CC6.1-6.3, ISO 27001 A.6.1.2	Complete user list with roles, permissions, last login, and expiration dates	IT Managers, Auditors, Quarterly (pre-certification)	Quarterly
Privileged Activity Summary	SOC 2 CC6.6-6.7, HIPAA 44 CFR 101.11	All actions by privileged users (admins, DBAs, etc.) with counts and sample logs	Security, Compliance, Monthly	Monthly
Data Access Log	GDPR Art. 28-32, CCPA 179B.185	Instances of PII access including IP, device, data accessed, and purpose	Legal, Data Protection, On-demand	On-demand
Configuration Change Log	SOC 2 CC8.1, ISO 27001 A.12.1.2	Chronological list of system configuration changes with approvals	IT Operations, Board, Change Management	Continuous
Security Incident Timeline	SOC 2 CC7.2-7.4, NIST IR	Detailed incident timeline from detection to resolution with root cause	Incident Response, Regulators, Post-mortem	As needed
Authentication Anomalies	SOC 2 CC7.1, NIST AC-7	Failed logins, impossible travel, session hijacking attempts	Security Operations, Real-time alerts	Real-time

9. API REFERENCE

All administrative capabilities are exposed via RESTful APIs following OpenAPI 3.0 specification standards. This API-first design ensures that any function accessible through the administrative user interface can also be executed programmatically, enabling automation, integration with external systems, and custom tooling development. The API gateway handles authentication, authorization, rate limiting, request validation, and response formatting consistently across all endpoints.

9.1 Authentication and Authorization APIs

Authentication endpoints handle user login, token refresh, session management, and multi-factor authentication flows. The API uses JWT (JSON Web Tokens) for stateless authentication with short-lived access tokens (15 minutes) and longer-lived refresh tokens (7 days). All sensitive endpoints require valid authentication, and privileged operations additionally require recent re-authentication (within 15 minutes) to confirm the operator's identity and intent.

Method	Endpoint	Description	Request Body	Response	Auth Require
POST	/api/v1/auth/login	Authenticate user; return tokens	{email, password, mfa_code}	{access_token, refresh_token, expires_in, user_info}	No
POST	/api/v1/auth/refresh	Obtain new access token	{refresh_token}	{access_token, expires_in}	No (valid refresh)
POST	/api/v1/auth/logout	Invalidate current session	{}	{message: 'logged out'}	Yes
POST	/api/v1/auth/mfa/enroll	Begin MFA enrollment	{method: 'totp' 'webauthn', secret}	{secret (TOTP) challenge (WebAuthn)}	Yes (WebAuthn)
POST	/api/v1/auth/mfa/verify	Complete MFA enrollment	{code response}	{recovery_codes, confirmed}	Yes (Re-auth)
GET	/api/v1/auth/sessions	List active sessions for user	{}	{session_id, ip, device, created_at, last_activity}	Yes
DELETE	/api/v1/auth/sessions/:id	Terminate specific session	{}	{message: 'session revoked'}	Yes (Re-auth)
POST	/api/v1/auth/impersonate	Start impersonation session	{target_user_id, token}	{impersonation_token, expires_in}	Yes (Super Admin)

9.2 User Management APIs

User management endpoints provide programmatic access to all user lifecycle operations. These APIs support the same validation, audit logging, and notification workflows as the UI-based operations, making them suitable for automated provisioning/deprovisioning integrations with HR systems, identity providers, and IT service management platforms. Bulk operations accept arrays of user objects or reference a previously uploaded CSV file via job ID.

Method	Endpoint	Description	Key Parameters	Notes
GET	/api/v1/admin/users	List users with filtering	role=&status=&org_id=&search=&page=&limit=&sort=	Requires pagination; respects column permissions
POST	/api/v1/admin/users	Create new user	{email, display_name, role_id, org_id, password, user_permissions}	Requires password strength; sends welcome email
GET	/api/v1/admin/users/:id	Get user details	:id (UUID)	Includes role assignments, group memberships

Method	Endpoint	Description	Key Parameters	Notes
PATCH	/api/v1/admin/users/:id	Update user fields	{fields to update}; supports partial updates	Validates each field; audits changes;
DELETE	/api/v1/admin/users/:id	Soft-delete user	?reason=&force=	Requires reason; force=true skips val
POST	/api/v1/admin/users/bulk-create	Batch create users	{users: [...]} or {job_id: 'csv-upload-async'}	Async; returns job ID for progress tra
POST	/api/v1/admin/users/bulk-update	Batch update users	{user_ids: [], updates: {...}}	Async; validates all before applying a
POST	/api/v1/admin/users/:id/unlock	Unlock locked account		Clears failed login counters; resets lo
POST	/api/v1/admin/users/:id/reset-password	Reset password	{new_password, require_change}	Invalidates existing sessions; sends n
GET	/api/v1/admin/users/:id/sessions	List user sessions	-	For session management; returns act

9.3 Tenant Management APIs

Tenant management APIs enable programmatic creation, configuration, and administration of organization tenants. These endpoints are primarily used by Super Administrators for MSSP customer onboarding, automated tenant provisioning, and cross-tenant operations. Most tenant endpoints require Super Administrator privileges due to the platform-wide impact of tenant configuration changes.

Method	Endpoint	Description	Key Parameters	Permissions
GET	/api/v1/admin/tenants	List tenants	?status=&plan=&created_after=	Super Admin: all; Org Admin: own or
POST	/api/v1/admin/tenants	Create new tenant	{name, display_name, plan_id, super_admin_config: {...}}	Super Admin only
GET	/api/v1/admin/tenants/:id	Get tenant details	:id (UUID)	Super Admin: full; Org Admin: own (
PATCH	/api/v1/admin/tenants/:id	Update tenant config	{config_changes: {...}}	Super Admin: all; Org Admin: allowe
POST	/api/v1/admin/tenants/:id/suspend	Suspend tenant	?reason=&duration=	Super Admin only; terminates all use
POST	/api/v1/admin/tenants/:id/resume	Resume suspended tenant		Super Admin only; re-enables authen
PUT	/api/v1/admin/tenants/:id/quota	Update tenant quota	{resource_limits: {...}}	Super Admin only; cannot reduce bel
GET	/api/v1/admin/tenants/:id/usage	Get usage statistics	?period=&granularity=	Super Admin: detailed; Org Admin: o
GET	/api/v1/admin/tenants/:id/audit	Get tenant audit log	?category=&start=&end=&limit=	Super Admin: all; Org Admin: own ev

9.4 System Configuration APIs

System configuration APIs provide access to platform-wide settings, integration management, and operational controls. These are the most sensitive endpoints in the administrative API, requiring Super Administrator privileges, recent re-authentication, and in some cases, explicit approval workflow completion before changes take effect. Configuration changes are versioned with full diff history, supporting immediate rollback if issues arise.

Method	Endpoint	Description	Key Parameters	Approval Required
GET	/api/v1/admin/config	Get all system config	?group=&include_defaults=	No
GET	/api/v1/admin/config/:key	Get specific config value	key (dot-notation path)	No
PUT	/api/v1/admin/config/:key	Update config value	{value:, justification:}	For sensitive keys (auth, security, billing)
POST	/api/v1/admin/config/rollback	Rollback to previous config	{config_key:, version:, reason:}	Yes (auto-approved if < 1 hour old)
GET	/api/v1/admin/integrations	List integrations	?type=&status=	No
POST	/api/v1/admin/integrations	Create integration	{type:, name:, config:{...}, credentials:}	For sensitive, credential-bearing integrations
PUT	/api/v1/admin/integrations/:id	Update integration	{config changes}	For credential or endpoint changes
POST	/api/v1/admin/integrations/:id/test	Test integration connectivity		No (read-only test)
DELETE	/api/v1/admin/integrations/:id	Remove integration	?force=&migrate_data_to=	Yes (data loss implication)
GET	/api/v1/admin/health	System health status	?deep=&component=	No (public endpoint with limited data)

10. BILLING/LICENSE INTEGRATION

The administrative interface integrates deeply with the CyberSOC Licensing Management System (LMS) to provide real-time visibility into license inventory, automate usage-based metering, enforce tier-specific limits, and support revenue operations. This integration ensures that administrative actions affecting licensed capacity (user creation, tier changes, feature enablement) are validated against the current license state before execution, preventing over-allocation and ensuring accurate billing.

10.1 License Inventory Synchronization

The LMS maintains the authoritative record of license allocations across all tiers and tenants. The administrative interface synchronizes with the LMS in near-real-time (cache TTL: 60 seconds) to present accurate license availability data. When an administrator performs an action that consumes license capacity (creating a user, upgrading a tier), the interface pre-validates against the cached license state and holds a temporary reservation while the action completes, preventing race conditions that could result in over-allocation.

License Attribute	Data Source	Sync Frequency	Display Context	Validation Rule
Total Seats (per tier)	LMS subscription table	60 seconds cache	License dashboard; user creation dialog	Cannot allocate seat if available <= 0
Allocated Seats	LMS allocation table	60 seconds cache	License dashboard; tenant details	Cached as sum of active user assignments
Available Seats	Computed: Total - Allocated	Realtime (derived)	License dashboard (prominent)	Warn if < 20%; Block if = 0
Expiration Date	LMS subscription records	Cache + webhook	Licenses list; tenant settings	Warn 60/30/7 days before; Block operation
Entitlement Features	LMS product catalog	5 minutes cache	Feature flags; integration	Hide/disable features not included in tier
Custom Limits	LMS amendment records	Cache + webhook	Quota display; enforcement	Enforce as floor (cannot go below even if 0)

10.2 Usage Metering and Analytics

The usage metering pipeline collects telemetry on consumable resources (API calls, storage, compute hours, data ingest volume) and reports aggregated metrics to the LMS for billing calculation. Administrative interfaces expose usage data through dashboards and reports, enabling both the platform operator (to track revenue) and tenant administrators (to manage costs) to understand consumption patterns and optimize resource utilization.

Metric Name	Unit	Collection Method	Granularity	Billing Relevance
Active User Seats	count (daily snapshot)	Session store query at midnight	Daily	Primary billing metric for seat-based tiers
API Calls	count	API gateway access logs	Per-request (aggregated hourly)	Usage calculation for API-tiered plans
Data Ingest (EPS)	events per second	Pipeline metrics (Prometheus)	1-minute averages (rolled hourly)	Capacity planning; potential overage metrics
Storage Consumed	gigabyte-hours	Object storage metrics	Hourly snapshots	Storage tier billing; retention cost attribution

Metric Name	Unit	Collection Method	Granularity	Billing Relevance
Concurrent Sessions	session-minutes	Session store duration tracking	Per-session (summed hourly)	Hourly metric; capacity planning
Compute Hours	vCPU-hours	Kubernetes resource metrics	Pod-level (summed hourly)	Reserved instance utilization; cost allocation
Report Generations	count	Report service logs	Per-generation	Feature usage tracking; potential metered feature
Data Exports	count + volume	Export service logs	Per-export	Premium feature; potential volume limits

10.3 Tier-Based Feature Enforcement

Feature enforcement ensures that tenant organizations can only access capabilities included in their subscribed tier. The enforcement operates at multiple layers: UI element visibility (hiding inaccessible features), API gateway rejection (blocking direct API calls to gated endpoints), and backend service validation (double-checking before executing restricted operations). This defense-in-depth approach ensures tier compliance regardless of the access method employed.

Feature/Capability	Free	Professional (\$149/yr)	Business (\$299/yr)	Enterprise (\$50K+/yr)	Enforcement Layer
User Seats	5	25	100	Unlimited	DB constraint + API validation
SIEM Integration	Basic (10 GB/day)	Standard (500 GB/day)	High (2 TB/day)	Custom	Ingest pipeline throttle
EDR Connectivity	Read-only	Full management	Full + RIR	Custom + API	EDR client capability token
SOAR Playbooks	10 built-in	100 built-in + 25 custom	Unlimited custom	Unlimited + shared	Playbook execution service
Threat Intel Feeds	Open source only	Commercial + OSINT	Premium commercial	Custom feeds	Feed connector license check
API Access Rate	1,000 req/min	10,000 req/min	50,000 req/min	Custom SLA	API gateway rate limiter
SSO/SAML 2.0	Not available	Available	Included	Advanced (IdP-initiated, JIT)	Auth, IDP middleware feature flag
Custom Branding	None	Logo + colors	Full white-label	Full + custom domain	Theme resolver + CDN routing
Support Level	Community	Business hours	24/7	Dedicated CSM	Routing tag in ticketing system
Audit Log Retention	30 days	90 days	1 year	7+ years	Index lifecycle policy
Compliance Reports	Basic (self-serve)	Standard templates	Custom + mapping	Full consultancy	Report generator feature gate

11. SECURITY REQUIREMENTS

The administrative interface represents a high-value target for adversaries due to the extensive privileges it controls. Security requirements for the admin interface exceed those for general platform functionality, implementing defense-in-depth controls across authentication, authorization, data protection, and monitoring dimensions. This section specifies mandatory security controls that must be implemented and verified before the admin interface can be deployed to production environments.

11.1 Authentication Security Controls

Administrative access requires stronger authentication than standard user access, reflecting the elevated risk profile of administrative actions. All administrators must enroll in multi-factor authentication (MFA) using hardware security keys (WebAuthn/FIDO2) or Time-based One-Time Password (TOTP) applications. Session lifetimes are shorter for administrative contexts, and sensitive operations require step-up authentication to confirm the operator's identity and intent immediately before execution.

Control	Requirement	Implementation	Verification Method
MFA Enforcement	100% of admin accounts must have MFA enabled	MFA is mandatory for all admin logins; MFA is blocked if disabled in user profile	Automated audit of user profiles; penetration testing
Session Timeout	Maximum 15 minutes idle; 8 hours maximum session lifetime	Idle timeout enforced by UI; session invalidated on logout or inactivity	Session hijacking tests; stolen credentials
Step-Up Auth	Re-authenticate for: role changes, sensitive operations	Step-up prompts for high-risk actions; requires additional factor	Privilege escalation tests; impersonation
Password Policy	Minimum 16 characters; 3 of 4 char types; 90-day max age	Enforced by password manager; no reuse of previous passwords	Brute force attacks; password reuse tests
Brute Force Protection	Account lockout after 3 failures; 30-minute cooldown	Rate limiting on login endpoints; exponential backoff for failures	Automated login attempts; password guessing
Device Trust	Remember trusted devices for 30 days	Device fingerprinting; MFA exemption for trusted devices	Device compromise tests; fingerprint spoofing

11.2 Authorization and Access Controls

Authorization decisions follow the principle of least privilege, granting administrators only the minimum permissions necessary to perform their assigned duties. Permission checks occur at the API gateway layer before any business logic executes, ensuring that unauthorized requests are rejected early with minimal information disclosure. The authorization engine caches permission decisions with short TTL (30 seconds) to balance performance with responsiveness to permission changes.

Control	Requirement	Implementation	Verification Method
Permission Granularity	47 discrete permissions across 12 functional areas	Least privilege principle; permissions mapped to specific admin actions	Permission audits; role-based access control (RBAC) testing
Scope Isolation	Org admins cannot access other org's data	Database row-level security; tenant isolation in APIs	Data leakage tests; cross-tenant access attempts
Separation of Duties	Sensitive actions require second approval	Workflow engine for critical actions; requires two distinct admins	Privilege abuse tests; approval bypass attempts
Privilege Escalation	Prevention of privilege escalation	Privilege checks on all actions; no direct escalation paths	Privilege escalation tests; role inheritance analysis
API Security	All admin APIs authenticated, encrypted	Gateway authentication; TLS for all admin endpoints	API security scans; MITM attacks

Control	Requirement	Implementation	Verification Method
Console Access Control	No direct database or server access from console	Backend services connected via API; network segmentation	Penetration testing, network logs

11.3 Data Protection Requirements

Administrative interfaces handle sensitive data including personally identifiable information (PII), authentication credentials, security configurations, and audit logs. Data protection controls ensure confidentiality (encryption at rest and in transit), integrity (tamper detection), and availability (appropriate access controls and backup) for all data classes processed by the admin interface.

Data Class	Examples	Encryption at Rest	Encryption in Transit	Access Logging
Highly Restricted	Passwords, MFA secrets, API keys, OAuth tokens	AES-256-GCM or HSM for FIPS; keys required to be rotated	TLS 1.3 required; certificate pinning	Access logs logged with user ID, IP, timestamp
Restricted	PII (SSN, passport), biometric templates	AES-256, applies tiered levels of protection	TLS 1.2 minimum, separate keys for PII	Access logged; PII access triggers additional review
Internal	User names, email addresses, internal IDs	AES-256, database transparent encryption (TDE)	TLS 1.2 minimum	Access logged on view/export; aggregated for reporting
Internal (Operational)	Configurations, audit logs, system metrics, job status	AES-256 or TDE, immutable storage	TLS 1.2 for config; plaintext for logs	Configuration changes logged; audit logs tamper-evident
Public	Documentation, help content, public API endpoints	Not required (if sensitive data) or commended; integrity checks	HTTPS for APIs; plaintext for docs	Access logging required for APIs

12. IMPLEMENTATION ROADMAP

The following roadmap outlines the phased approach for implementing the administrative interface, sequencing work items to deliver incremental value while managing dependencies between components. The timeline assumes a dedicated team of 2-3 frontend developers, 1-2 backend developers, and 0.5 QA engineer working over approximately 12-16 weeks. Adjustments may be needed based on team capacity, existing codebase familiarity, and integration complexity.

Phase	Duration	Deliverables	Dependencies	Success Criteria
Phase 1: Foundation (Weeks 1-3)	3 weeks	- Auth middleware hardening - RBAC engine core - Basic user CRUD - Audit logging infrastructure - Admin layout shell	Database schema finalized Auth service stable Design system established	Users can be created/edited/deleted via API; Permission checks enforced; Audit events written for all mutations
Phase 2: Core Modules (Weeks 4-7)	4 weeks	- User management UI (list, details, forms) - Role management (CRUD + permissions) - Session management views - Dashboard framework - System overview dashboard	Phase 1 complete UI component library ready API specs finalized	All user operations available in UI; Roles can be created and assigned; Dashboard renders with real data
Phase 3: Advanced Features (Weeks 8-10)	3 weeks	- Tenant management (CRUD, bulk) - Bulk operations (upload, progress) - License integration (display) - Usage analytics dashboard - Notification system	Phase 2 complete Payment API available Telemetry pipeline active	Tenants can be provisioned; Bulk user operations work; License data displays accurately
Phase 4: Security Hardening (Weeks 11-12)	2 weeks	- Step-up authentication flows - Approval workflows - Session anomaly detection - Security policy UI - Penetration test remediation	Phase 3 complete Security review completed Pen test scheduled	All security controls per Section 11 implemented No critical/high findings from pen test
Phase 5: Polish & Deployment (Weeks 13-14)	2 weeks	- Performance optimization - Accessibility (WCAG 2.1 AA) - Documentation (user guide, SOPs) - Training materials - Production deployment	Phase 4 complete Staging environment validated Sign-off from security/DevOps	Page load < 3 seconds; Accessibility audit passes; Docs published; Go-live approved

12.1 Risk Factors and Mitigations

Risk	Probability	Impact	Mitigation Strategy	Contingency
Scope creep from stakeholders	High	Medium	Strict change control; defer non-MVP features to post-launch	Communicate with stakeholders; maintain a backlog for future releases
Integration delays (LMS, email provider)	Medium	High	Early integration testing (Week 2); implement stubs for external services	Identify alternative providers; adjust timeline if needed
Security findings delay launch	Medium	High	Embed security engineer in team; conduct regular security scans	Communicate findings and mitigation progress to stakeholders
Performance issues at scale	Medium	Medium	Load testing from Week 10; performance budget enforcement	Implement caching; optimize database queries; consider CDN
Team availability/capacity constraints	Low	High	Buffer time in estimates (20%); cross-train team members	Re-evaluate resource allocation; consider external support if critical

APPENDIX A: UI MOCKUP DESCRIPTIONS

This appendix provides detailed textual descriptions of the key administrative interface screens, serving as specifications for UI/UX designers and frontend developers. Each screen description includes the layout structure, component inventory, interaction patterns, and responsive behavior breakpoints. The design follows the CyberSOC Cascade Palette design system established in previous platform deliverables, ensuring visual consistency with existing dashboard and analyst interfaces.

Screen Name	Layout	Key Components	Interactions
Login Page	Centered card (480px wide)	Username input, Password input, Forgot password link, Login button	Click to login, Click to reset password, Click to register
Admin Dashboard	4-column grid (responsive)	Stat cards (4), Chart widgets (2), Notifications (3), Quick actions (1), Alerts (1)	Click to view details, Click to filter, Click to dismiss
User List	Full-width table with toolbar	Search bar, Filter dropdown, Sort select, Table rows, Action icons	Click to search, Click to filter, Click to sort, Click to edit/delete
User Detail	Two-column layout (2:1 ratio)	User info (name, email, status), Role assignment, Permissions, Audit log	Click to edit, Click to assign role, Click to view logs
Role Editor	Modal dialog (large, 800px)	Role name, Description, Permissions list, Save/Cancel buttons	Click to save, Click to cancel, Click to refresh
Tenant Wizard	Multi-step wizard (stepper)	Step 1: Basic info, Step 2: Plan selection, Step 3: Billing details	Click to next, Click to previous, Click to cancel

APPENDIX B: DATABASE SCHEMA REFERENCE

This appendix defines the core database tables required to support the administrative interface. The schema is designed for PostgreSQL 15+ with considerations for query performance, data integrity, and auditability. Tables are organized by functional domain with foreign key relationships explicitly defined. Index recommendations balance read performance against write overhead for the expected workload patterns.

Table Name	Purpose	Key Columns	Indexes	Est. Rows
users	User account master	id (PK, UUID), email (unique, indexed), username (unique), password_hash (text), last_login (timestamp), is_active (boolean)	id (B-tree), email (B-tree), username (B-tree), last_login (B-tree)	10,000
roles	Role definitions	id (PK, UUID), name (unique within scope), display_name (text), scope (enum: global/or-tenant)	id (B-tree), name (B-tree)	2,000
permissions	Permission registry	id (PK, UUID), code (unique), domain (enum: system/table)	id (B-tree), code (B-tree)	40,000
role_permissions	Many-to-many role-permission mapping	role_id (FK, PK), permission_id (FK, PK)	role_id (B-tree), permission_id (B-tree)	50,000
user_roles	User role assignments	id (PK, UUID), user_id (FK), role_id (FK), assigned_by (FK, UUID)	id (B-tree), user_id (B-tree), role_id (B-tree)	100,000
tenants	Organization/tenant records	id (PK, UUID), name, display_name, slug (unique), status (enum: active/suspended)	id (B-tree), slug (B-tree)	1,000
tenant_quotas	Resource limits per tenant	tenant_id (FK, PK), resource_type (enum: cpu/memory/disk), limit_value (integer)	tenant_id (B-tree), resource_type (B-tree)	5,000
audit_events	Immutable audit log	id (PK, UUID), event_type, actor_id (FK, UUID), timestamp (timestamp), target_id (FK, UUID)	id (B-tree), timestamp (B-tree)	1,000,000
config_entries	System/Tenant configuration	id (PK, UUID), key (unique), value (JSONB)	id (B-tree), key (B-tree)	10,000
integration_configs	External integration settings	tenant_id (FK, PK), integration_id (FK), type (enum: webhook/api), config (JSONB), status (enum: active/inactive)	tenant_id (B-tree), integration_id (B-tree)	5,000

APPENDIX C: ERROR CODE CATALOG

The administrative API uses structured error codes to enable programmatic error handling and clear user communication. Errors follow the RFC 7807 Problem Details format with a custom `code` field for machine readability. This catalog enumerates all error codes that admin API clients should anticipate and handle appropriately. Codes are organized by HTTP status code and functional domain to facilitate quick lookup during integration development.

TTP Status	Error Code	Message Template	When Returned	Client Action
400	INVALID_REQUEST_BODY	Request body validation failed: {details}	Required fields missing; wrong data type or malformed JSON	Validate inputs; correct format
400	DUPLICATE_VALUE	A record with this {field} already exists	Creating user with existing email or existing role with existing name	Check for existing records; use unique identifiers
400	QUOTA_EXCEEDED	Resource quota exceeded for {resource_type}	Creating {resource_type} (exceeded per-tenant storage or user licenses)	Reduce usage; upgrade plan if necessary
401	AUTHENTICATION_REQUIRED	Authentication credentials required	Missing or invalid Authorization header or expired token	Obtain fresh credentials; refresh token
401	INVALID_CREDENTIALS	Invalid email or password	Login attempt with wrong password	Verify credentials; offer password reset
401	MFA_REQUIRED	Multi-factor authentication required	User has MFA enrolled but did not provide code	Prompt for MFA code; restart auth flow
401	TOKEN_EXPIRED	Authentication token has expired	Using access token past expiry (5 token)	Refresh token; if refresh fails, re-login
403	INSUFFICIENT_PERMISSIONS	Access denied: requires {required_permission}	User/role lacks permission for requested action	Request elevated privileges; inform user of limitations
403	SCOPE_VIOLATION	Operation not permitted in current context	Org admin trying to access tenant-specific data	Verify context and user role; use appropriate endpoint
403	ACCOUNT_LOCKED	User account is locked: {reason}	Too many failed logins; admin manually locked	Wait for lockout period; contact support
403	TENANT_SUSPENDED	Tenant account is suspended: {reason}	Organization suspended for non-compliance	Review terms of service; resolve suspension
404	RESOURCE_NOT_FOUND	Resource {resource_type} with id '{id}' not found	Referenced user/role/tenant does not exist	Verify resource ID; handle gracefully
409	CONCURRENT_MODIFICATION	Resource was modified since request	Optimistic lock failure; simultaneous updates	Retry with exponential backoff
422	BUSINESS_RULE_VIOLATION	Business rule violation: {rule}	Attempting to create role with conflicting permissions	Review role configuration; suggest alternatives
429	RATE_LIMIT_EXCEEDED	Rate limit exceeded: try again after {retry_after} seconds	Too many requests in time window	Implement backoff; display countdown
500	INTERNAL_ERROR	An unexpected error occurred: {message}	Unhandled exception in server logic	Retry with exponential backoff; report to support
503	SERVICE_UNAVAILABLE	Service temporarily unavailable	Dependency (database, LMS, auth provider) down	Retry after some time; display maintenance message